

Lab 6: The Letter You Carry — Scoping, Authorization, and the Four Gates

Session 6 — Rules of Engagement

Course: Hands-On Ethical Hacking and Network Defense, 4e — Module 1 companion lab **Estimated time:** 90 minutes

Prerequisite: Labs 1–5 completed, or at minimum familiarity with the Four Gates and the Rules of Engagement material from Module 1. **Format:** Written — no VM required for this session. **Based on:** Module 1’s “Authorisation Is Everything,” “Rules of Engagement: What Has to Be in Writing,” “The Letter You Carry,” and “The Ethical Hacker’s Code.”

1. Learning Objectives

By the end of this session you will be able to:

- Turn a vague client request into a scoped, written engagement using the Rules of Engagement checklist
- Draft an authorization letter containing all five elements the module identifies as load-bearing
- Apply the Four Gates test to a scenario before deciding whether to act
- Distinguish a legal action, a grey area, and a crime, using the same reasoning as the module’s own case-study activity — on scenarios you haven’t seen answers for
- Apply the Ethical Hacker’s Code to a specific, concrete situation rather than reciting it

2. The Scenario

(Read this once. You’ll return to it in every part below.)

A small logistics company, **Harrow Freight Solutions**, emails you: “We think our website might be hackable — a competitor keeps beating us to bids and we’re wondering if someone’s reading our systems. Can you take a look this week? Our IT guy Dave will get you whatever access you need. No need for a big contract, we trust you — just send an invoice when you’re done.”

A follow-up call establishes: Dave is the IT contact, not an owner or executive. The company’s website is hosted by a third-party web agency. Harrow also uses a cloud-based bidding portal run by a separate vendor, which Dave says “you should probably check too, since that’s where the leaks might be.”

This request has real red flags in it. Finding them is the point of Parts A–C.

3. Procedure

Part A — Run the Four Gates

For each of the Four Gates — written permission, in-scope host, permitted technique, inside the window — state whether the scenario currently satisfies it, and if not, what would need to happen before it does.

Part B — Find the Red Flags

Using the module’s own “red flags in a scoping call” list as your checklist, identify **at least three** specific red flags in the Harrow scenario. For each, quote or paraphrase the exact line in the scenario that triggers it, and say which category of the Rules of Engagement checklist it threatens (named targets, authority to sign, dates and windows, permitted techniques, data handling, or emergency contacts).

Part C — Decide What’s In Scope

The cloud-based bidding portal is run by a separate vendor. Using the module’s own reasoning about third-party and cloud-hosted assets, decide: can you include it in your test based on Dave’s say-so? Justify your answer in 2–3 sentences.

Part D — Draft the Rules of Engagement

Using the six categories from Module 1’s checklist, write a Rules of Engagement summary for Harrow **as it should be**, not as Dave first described it. For each category, write one to two sentences of what you would insist on before starting:

1. Named targets (and what’s explicitly out of scope)
2. Dates and windows

3. Permitted techniques
4. Emergency contacts
5. Data handling
6. Authority to sign

Part E — Draft the Letter You Carry

Write a short authorization letter for this engagement, containing all five elements the module identifies:

1. Who is authorizing the test, and how they prove they can
2. Exactly what's in scope (and what's explicitly not)
3. The testing window
4. What you may **not** do, stated positively
5. Who to call if something goes wrong, and how to reach them

You're writing the letter as it should exist once the red flags from Part B are resolved — not one that lets Dave's original email stand as-is.

Part F — Legal, Grey Area, or Crime?

Decide a verdict — **Legal**, **Grey Area**, or **Crime** — for each of the four scenarios below, and name the statute (CFAA, ECPA, or ITADA) that's most relevant if the verdict is Crime. One or two sentences of reasoning each; there's no answer key to flip to this time.

1. Dave emails you the cloud bidding portal's admin login "just so you don't have to bother asking the vendor."
2. Two days into an authorized test, you notice unrelated unencrypted email traffic crossing the same segment you're scanning, and you let Wireshark keep capturing it out of curiosity.
3. Your signed scope covers Harrow's own servers only. While testing, you discover the web agency's shared hosting panel is reachable with default credentials, and you log in to see how far it goes.
4. Harrow's engagement ends Friday at 5 p.m. per the letter. You finish your report over the weekend using data you already collected during the window.

Part G — Pick the Engagement Type and Model

Based on what Harrow actually said they want to learn ("we think our website might be hackable"), decide:

1. Which of the module's three engagement types (vulnerability assessment, penetration test, security test) fits this request?
2. Which testing model (white box, grey box, black box) fits, using "the question that picks the model" from the module — and defend it against the alternative Harrow might assume they want.

Part H — Apply the Ethical Hacker's Code

For each of the five habits below, write one sentence describing what it concretely requires you to do **in the Harrow engagement specifically** — not a general definition.

1. Authorization before action
2. Stay inside the scope
3. Do no avoidable harm
4. Protect what you find
5. Report honestly

4. What to Submit

Your completed responses to Parts A–H, as a single written document. There is no code, log, or screenshot in this lab — the deliverable is the paperwork itself, because the module's own point is that paperwork, not skill, is what decides most outcomes.

5. Reflection

Question 1 (2–3 sentences): Look back at Lab 3. If you had pointed that same `vsftpd` exploit at a host outside `192.168.56.0/24` — say, a machine on your home network — which of the Four Gates would you have failed, and would any amount of technical skill have made it legal?

Question 2 (1–2 sentences): The module argues that report-writing, not exploitation, is where a tester's real skill shows. After Parts D and E of this lab, do you agree, or has this session changed your view of which part of the work is actually harder?

6. Notes for Instructors

This is a paperwork lab: no VM is required, and it can be run as a written assignment, an in-class workshop, or a small-group exercise. Parts F and G work well as a live discussion after students submit individual answers, since — as the module's own version of this activity shows — the reasoning is often more contested than the verdict.

This is the last Module 1 lab. Everything from here builds on the environment (Lab 1), the recon-to-exploit chain (Labs 2–4), the web-application skills (Lab 5), and the paperwork (Lab 6) you now have in place.